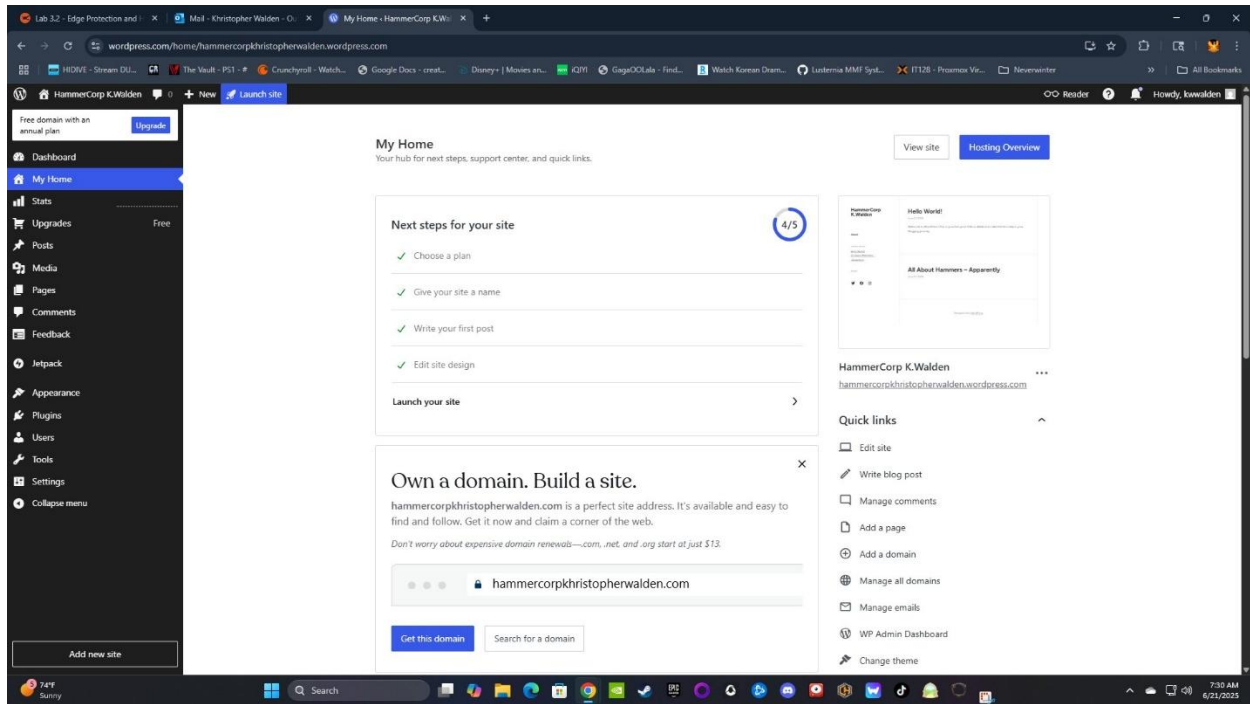
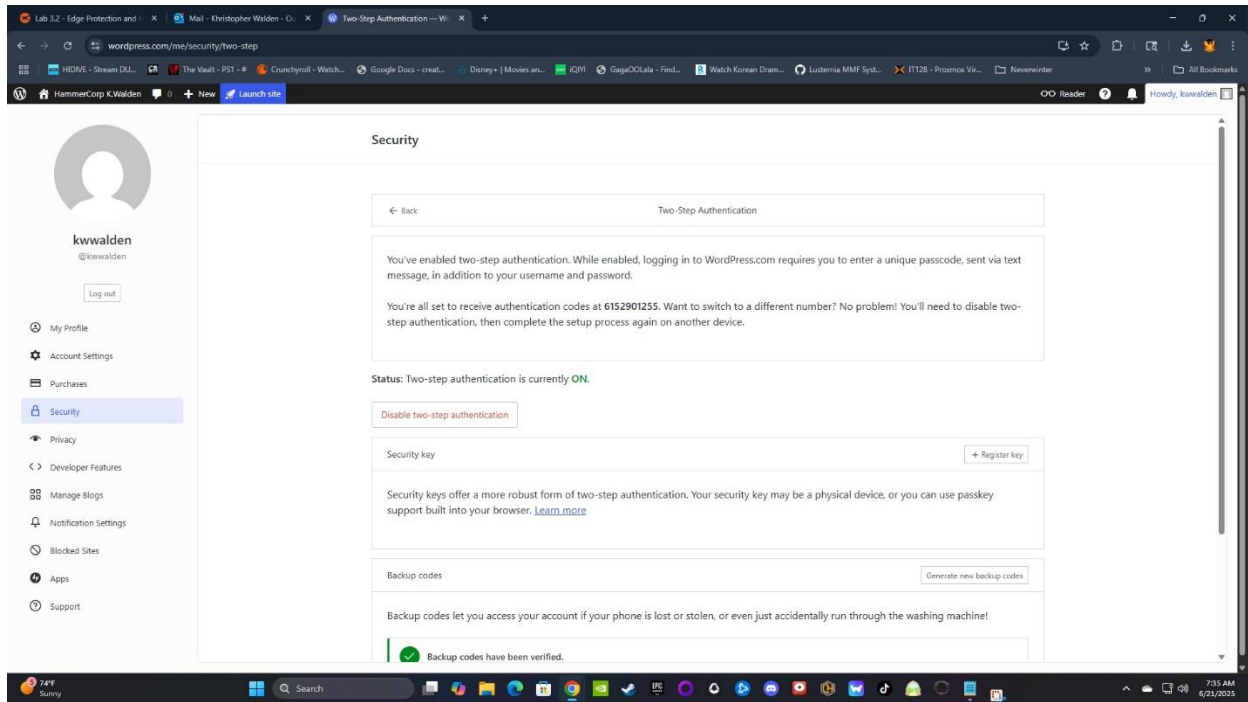


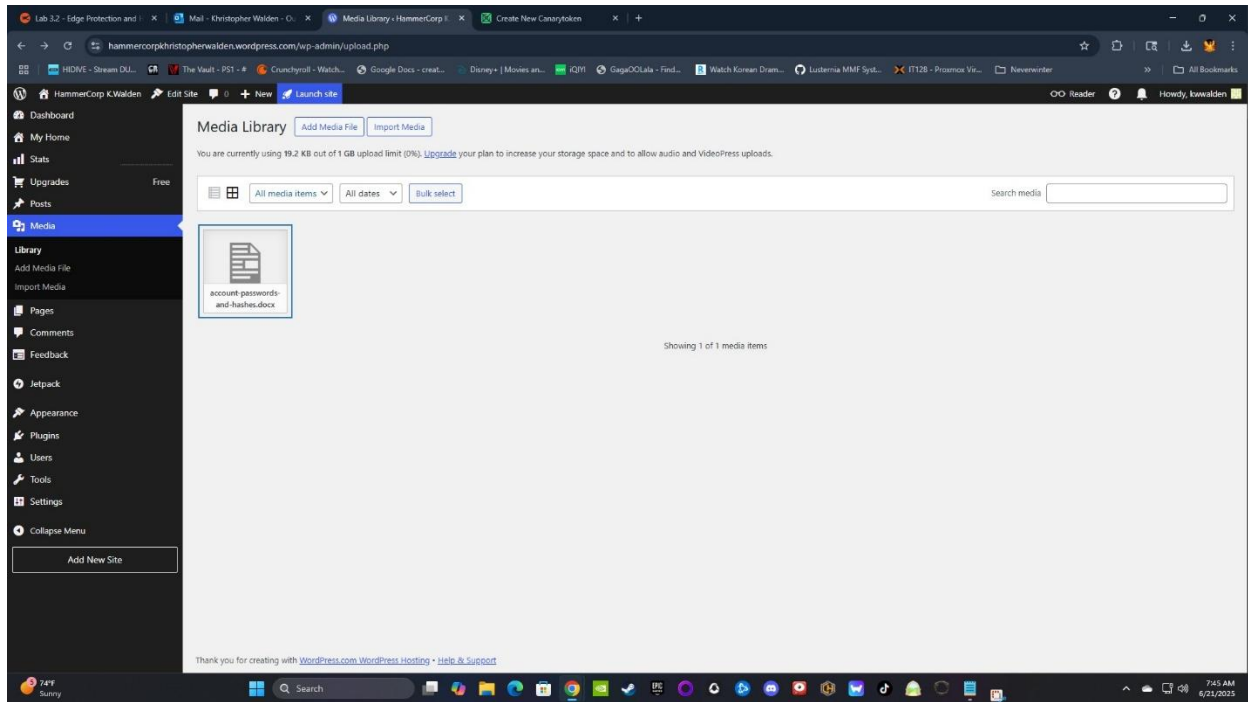
WordPress Dashboard



Two-Factor Authentication



File System Backup



WordPress Media Library showing token and URL

The screenshot shows the WordPress Media Library 'Edit Media' interface. The main content area displays the following information:

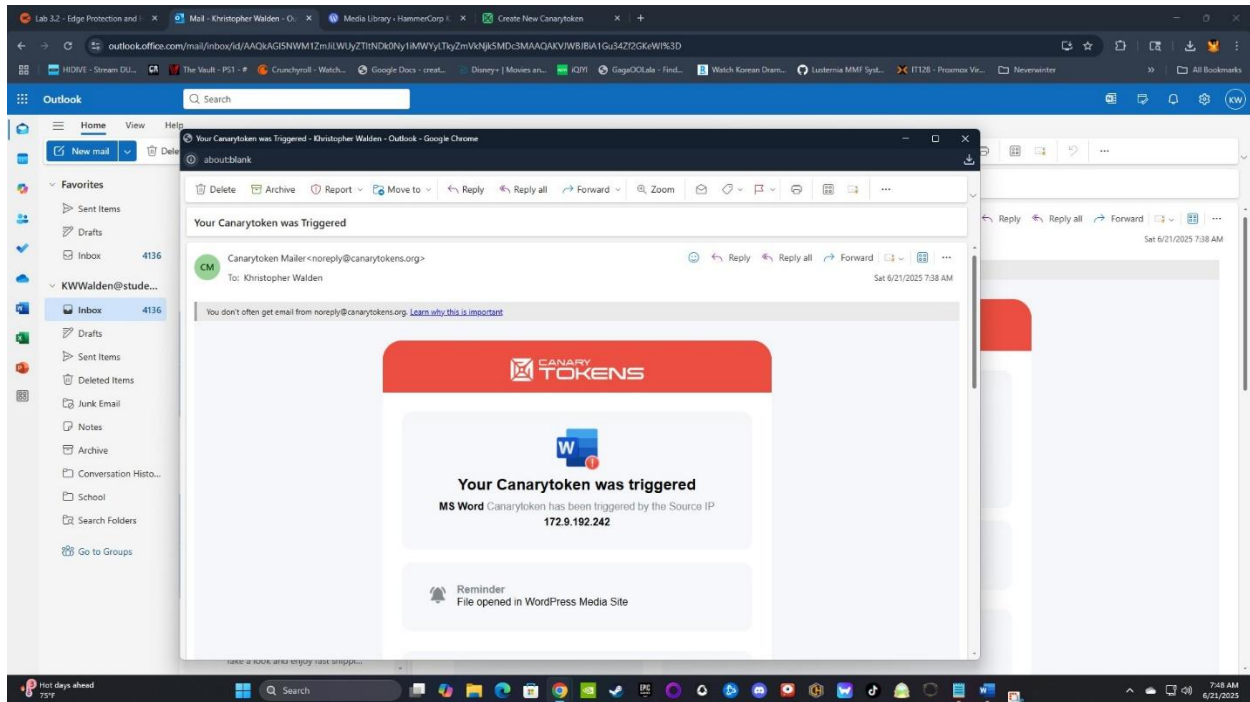
- Title:** Account Passwords and Hashes
- Permalink:** <https://hammercorp.kristopherwalden.wordpress.com/account-passwords-and-hashes/> (with a 'Get Shortlink' button)
- Caption:** (Empty text field)
- Description:** (Empty text field with a rich text editor toolbar)

On the right side, the 'Save' panel shows the following details:

- Uploaded on:** Jun 21, 2023 at 07:41
- Uploaded by:** kowalden
- File URL:** <https://hammercorp.kristopherwalden.com/> (with a 'Copy URL to clipboard' button)
- Download file** (button)
- File name:** account-passwords-and-hashes.docx
- File type:** DOCX
- File size:** 19 KB
- Actions:** [Delete permanently](#) and [Update](#) buttons
- Likes and Shares:** ☒ Show likes, ☒ Show sharing buttons

The left sidebar contains the WordPress dashboard menu, with 'Media' highlighted. The bottom status bar shows the time as 7:44 AM on 6/21/2023.

Token Triggered



Lab Write-up

1. Why does moving publically facing marketing websites out of your datacenter improve security?

Relocating publicly facing marketing websites from an internal datacenter to a segmented, external hosting environment such as a cloud-based web hosting platform enhances security by reducing the organization's overall attack surface. Datacenters that host sensitive internal resources—like customer databases or enterprise applications—are high-value targets for attackers. By isolating public-facing components, such as a marketing site, from critical internal infrastructure, an organization can limit the damage from a breach. If the marketing site is compromised, the attack is confined to the external environment, thereby preserving the integrity of the core systems within the datacenter. This strategic separation aligns with the principle of network segmentation, which is a fundamental tenet of secure architecture design, reducing the likelihood of lateral movement by threat actors within the network.

2. How does two-factor authentication prevent brute force attacks?

Two-factor authentication (2FA) significantly mitigates brute force attacks by requiring more than just a username and password to gain access to a system. Brute force attacks rely on systematically guessing or cracking credentials, but 2FA introduces a second layer of security—typically something the user has (like a time-sensitive code from a mobile app or hardware token) or something the user is (biometric data). Even if an attacker successfully guesses or steals a user's password, they still cannot bypass the second factor without access to the user's personal device or biometric data. This drastically reduces the success rate of brute force attacks and helps protect accounts from being compromised through credential stuffing or dictionary attacks.

3. What is the main type of damage that could be done to HammerCorp if someone were to compromise the external HammerCorp Wordpress site?

If HammerCorp's external WordPress site were compromised, the most immediate and damaging impact would likely be reputational harm and the potential for malware distribution to clients and visitors. A compromised site can be used to host phishing pages, inject malicious scripts (e.g., drive-by downloads or cryptojacking), or redirect users to unsafe domains, thereby eroding customer trust and brand credibility. Furthermore, attackers might deface the website, altering its content to display offensive material or propaganda. While this may not directly breach sensitive internal data, the public visibility

of the marketing site makes it a prime vector for undermining the company's professional image, potentially leading to loss of business and costly incident response efforts.

4. What is the most important part of keeping a Wordpress site secure? (Hint: We talked about it in OS Hardening)

The most crucial aspect of keeping a WordPress site secure is maintaining timely and consistent updates of the WordPress core, themes, and plugins—an essential aspect of operating system (OS) and application hardening. Many WordPress vulnerabilities arise from outdated components that contain known security flaws which attackers can easily exploit. Regularly applying updates ensure that newly discovered vulnerabilities are patched before they can be targeted. Additionally, disabling unnecessary plugins, using strong file permissions, and employing security plugins for firewalls and login protection all contribute to hardening the system. However, none of these measures are effective if the site runs on outdated code, making updates the most foundational and non-negotiable aspect of WordPress security.

5. How could an attacker stop Canary Tokens from working?

An attacker could potentially stop Canary Tokens from working by identifying and isolating the token triggers before they are activated. This could involve analyzing suspicious-looking files or links in a controlled environment, such as a sandbox or isolated virtual machine, where outbound network traffic is restricted. If the attacker prevents the token from reaching its notification endpoint—by blocking DNS lookups, HTTP requests, or disabling Internet access, the alert system tied to the token may never receive a signal. Skilled attackers may also recognize the pattern or signature of a Canary Token and simply avoid interacting with it, rendering it ineffective as a tripwire. However, the stealth and variety of Canary Tokens make complete avoidance challenging.

6. Where else could you deploy Canary Tokens to detect attacks?

Canary Tokens can be deployed in a wide variety of digital and physical contexts to detect unauthorized access or suspicious activity. Common locations include email inboxes (as hidden links or files), database records (as bait entries), internal file shares, cloud storage locations (like Google Drive or AWS S3 buckets), and network-attached storage systems. Tokens can also be embedded in fake API keys or AWS credentials within code repositories such as GitHub. The idea is to place these tokens where no legitimate user would interact with them under normal operations, so any access or activation signals a likely intrusion or insider threat. Deploying tokens in diverse locations improves visibility and enhances incident detection capabilities across an organization's infrastructure.

7. What kind other tokens can be created other than Word Docx?

Besides Word DOCX files, Canary Tokens can be created in a variety of formats tailored to mimic different assets that attackers typically target. These include PDF documents, Excel spreadsheets, AWS API keys, web URLs, SSH private keys, Windows executables, and DNS-based tokens. Each type serves to lure attackers by presenting them as a valuable resource or credential, and each can be configured to alert security teams when interacting with. For instance, a fake AWS key placed in a public GitHub repository can notify an organization if anyone attempts to use it, while a DNS token embedded in a document will trigger an alert when opened and a DNS request is made. This versatility allows defenders to tailor their detection strategies based on likely attack vectors and their specific threat landscape.